

Enhancing Banking Authentication Systems with LLMs and RAG: Addressing Ethical and Privacy Challenges

Kwaku Addae-Mensah and Yanzhen Qu*

ABSTRACT

Banking access control security can be improved by integrating Large Language Models (LLMs) customized with Retrieval-Augmented Generation (RAG) architecture into banking authentication systems. Deploying these systems may cause significant ethical challenges and privacy-related issues that expose data, produce biased decisions, and force companies to break the rules and regulations. This paper investigates these security issues using a Design Science Research (DSR)-based LLM and RAG enabled banking authentication system. The artifact incorporates privacy-preserving artificial intelligence techniques and explainable artificial intelligence functions to protect data integrity and meet General Data Protection Regulation (GDPR) and Payment Card Industry Data Security Standard (PCIDSS) regulatory criteria. An extensive set of experimental simulations involving 550 typical banking authentication use cases confirmed that security systems built upon LLM and RAG technology produce superior banking authentication outcomes regarding transparency, fairness, and privacy safeguards. This research indicates that AI-based banking authentication systems must focus on responsible AI governance, regulatory adherence, and fairness protocols to provide secure bank environments.

Keywords: Banking authentication system, compliance, large language models, retrieval-augmented generation.

Submitted: April 21, 2025

Published: June 25, 2025

 10.24018/ejece.2025.9.3.715

Colorado Technical University, USA.

*Corresponding Author:
e-mail: yqu@coloradotech.edu

1. INTRODUCTION

The introduction of AI technology into authentication systems in banking creates both advantageous opportunities and several implementation hurdles to address. The latest development to enhancing secured banking authentication system is integrating Large Language Models (LLMs) with the banking security needed customization via the Retrieval-Augmented Generation (RAG) architecture [1]. AI-driven banking authentication systems outperform traditional Personal Identification Number (PIN) based authentication systems because they use dynamic security measures that analyze user behavior in real-time, leveraging machine learning algorithms to detect anomalies and potential fraud. These systems enhance security by continuously adapting to new threats, providing personalized authentication experiences, and reducing the risk of unauthorized access. Additionally, AI-driven systems offer improved accuracy and efficiency, minimizing false positives and ensuring a seamless user experience.

However, the deployment of these state-of-the-art authentication systems produces essential privacy-related ethical dilemmas. Banking security solutions need improvements concerning algorithmic bias, transparency issues, and proper data management to become trustworthy and fair banking practices [2].

An LLM-RAG enhanced banking authentication system that addresses security and fairness and implements transparency features along with data protection measures is presented in this paper. Security standards increase through the proposed system's real-time contextual analysis, which powers adaptive authentication systems. To achieve fair access, the system incorporates bias mitigation tools that stop discriminatory choices from being made. Explainable Artificial Intelligence (XAI) mechanisms act as explainable artificial intelligence strategies to give users and regulatory authorities a better understanding of AI-based authentication processes [3]. The system protects



sensitive user data through federated learning and differential privacy methods, which implement privacy-preserving techniques [4]. We adopted a Design Science Research (DSR) methodology to integrate an LLM customized with RAG into a banking authentication system that creates a strong framework that reduces security risks in banking authentication systems. The proposed artifact comprises bias auditing functions, model explainability features, and privacy protections to deliver ethical AI deployment in banking access control. This research's evidence shows how AI authentication systems comply with regulations to build user trust and meet legal standards including General Data Protection Regulation (GDPR) Payment Card Industry Data Security Standard (PCIDSS) and AI Act standards, to remain compliant with regulations [5].

2. RELATED WORKS

2.1. AI and Ethics in Banking

Integrating a Large Language Model customized with the Retrieval-Augmented Generation architecture into a banking authentication system delivers a security method that adapts and evolves for banking authentication systems. Advanced Large Language Models with Retrieval-Augmented Generation need proper ethical management because fairness biases and interpretability flaws must be controlled to implement responsible Artificial Intelligence. Research shows that security authentication solutions managed by AI require equal protection of user rights to provide equal access to financial services to all customers across all demographics and socioeconomic levels [6]. The main ethical problem with the AI-based authentication models may arise from biased training data sets, potentially creating unjustified barriers or privileges stemming from existing social inequality. Systems that lack representative demographic data during training can produce discriminatory authentication results that deliberately affect vulnerable groups of people. Perpetual monitoring and fairness-guided training must be employed to handle these bias factors. The “black box” problem refers to insufficient visibility of how AI systems achieve their decisions, a significant obstacle to system implementation [7]. Financial institutions face difficulties understanding the methods through which AI-based authentication models make decisions, thus hindering their ability to explain the denial of user access. No explainable functionality within systems poses problems relating to responsibility tracking and regulatory requirements [5].

2.2. Privacy Concerns with LLMs and RAG

Systemwide privacy issues emerge from Large Language Models (LLMs) utilized in banking authentication systems since the LLMs process very large volumes of confidential customers' and banking data. The Retrieval-Augmented Generation (RAG) architecture improves AI responses through real-time information retrieval, which generates additional data privacy concerns because it raises the possibility of unlawful data access and exposure combined with non-compliance [6]. Protecting customer data privacy through strict protocols for AI systems remains essential

in sustaining customer trust and adhering to the General Data Protection Regulation (GDPR) and U.S. banking privacy laws [9]. If the LLM used in the AI-driven banking authentication system has incorrect data management, or unintentionally exposes authentication information, it can create opportunities for security breaches. The immediate data retrieval function in RAG systems generates extra security hazards because unauthorized users who gain access to retrieved information raise the probability of compliance violations [3].

Strict data access control implementation by banks becomes essential to protect customer information because, without this security, users face cyber damage risks alongside possible regulatory sanctions. Secure data protection and enhanced system security results from implementing multiple privacy-enhancing technologies (PETs) within any banking authentication system that integrates an LLM. Federated Learning minimizes exposure risks by allowing the system to process data on local user devices instead of centralized storage [10]. The differential privacy framework stops individuals from rebuilding banking transaction data by ensuring anonymity. Access Control Policies combine with data minimization techniques to fulfill GDPR and other financial regulations requirements. Implementing privacy safeguards within AI-driven banking authentication systems allows for secure data protection and system protection [7]. These security protocols help organizations achieve compliance goals through data protection and create trusted relationships with customers who have peace of mind about their private financial information.

2.3. Regulatory Compliance in AI-driven Banking

Banking authentication systems that utilize artificial intelligence (AI) face regulatory compliance as their main priority because the integration of AI into banking services continues to increase. Financial institutions must follow three primary legal frameworks: GDPR, PCIDSS, and the AI Act, which require transparency, fairness, and explainable operations using AI security solutions [11]. The regulations demand that AI decision processes be both interpretable and transparent for automated authentication systems to maintain their auditable and legal compliance status. The primary difficulty facing AI-driven banking security comes from its non-explainable nature, which is commonly called the “black-box” problem [8]. Security measures become untenable for financial institutions because machine learning models, especially LLMs, produce authentication decisions that yield poor interpretability during security validations or compliance audits. The need for explainable AI (XAI) frameworks emerges through research as a solution to make AI-based authentication processes transparent, allowing financial regulators and institutions to validate AI-driven decisions [13].

Implementing Large Language Models (LLMs) and Retrieval-Augmented Generation (RAG) for banking authentication improves security but generates ethical dilemmas. Adopting AI-based systems improves fraud detection but creates new threats regarding data disclosure, algorithm biases, and regulatory violations [14]. Security

breaches against financial institutions become more likely when traditional authentication systems use static rules because they cannot keep up with updated fraud methods. Some research investigated how integrating LLM technology into banking authentication artifacts can help resolve security dangers while upholding ethical AI implementation and maintaining fairness standards with regulatory rules [11].

3. PROBLEM STATEMENT, HYPOTHESIS STATEMENTS, AND RESEARCH QUESTIONS

3.1. Problem Statement

The LLM and RAG based banking authentication systems may present the risk of new security threats regarding customer data disclosure, algorithm biases, and regulatory violations if the new authentication systems are not carefully designed under the guidance of GDPR, PCIDSS and XAI.

3.2. Hypothesis Statement

Integrating LLMs and RAG into banking authentication systems under the guidance of GDPR, PCIDSS and XAI significantly enhances ethical and privacy compliance by improving transparency, fairness, and regulatory alignment.

3.3. Research Question

How can LLMs and RAG-based authentication systems be designed under the guidance of GDPR, PCIDSS and XAI to ensure ethical AI governance, privacy compliance, and security enhancement in banking access control?

4. METHODOLOGY

4.1. Method

We have used Design Science Research (DSR) techniques to create an LLM customized with the RAG architecture into a banking authentication system that enhances the banking access control security while ensuring fairness and compliance with regulations. DSR proves ideal in this research since its main objective targets innovative solution development and evaluation for real-world problems. The artifact implements four essential components that enhance the authentication process at banks. Dynamic authentication employs LLMs to inspect active user behavior in real-time, which helps the system readjust authentication procedures based on observed behavioral and environmental elements. XAI introduces transparency by explaining access control decisions to financial institutions and regulators, allowing them to understand authentication results better [15]. A bias auditing module operates alongside the system to discover and minimize discrimination hazards and resolve algorithm fairness problems. As a final security layer, banking data undergoes protection through encryption, federated learning, and differential privacy methods, all of which comply with legal and regulatory requirements. Retrieval-Augmented Generation (RAG) enhances the system's ability to access and utilize relevant information dynamically, improving

the accuracy and efficiency of authentication processes. The implementation of Large Language Models (LLMs) and Retrieval-Augmented Generation (RAG) for banking authentication requires substantial data that exposes Personally Identifiable Information (PII). The blockchain-enabled data collection process addresses all risks by ensuring user privacy protection and fulfillment of regulatory norms. Named Entity Recognition (NER) models operated as the data anonymization tool through which personal information was eliminated to satisfy General Data Protection Regulation (GDPR) and banking privacy regulations such as Payment Card Industry Data Security Standard (PCIDSS).

Differential privacy techniques integrated noise attacks against sensitive data such as transaction amounts and location data to stop user identification. The system implemented automatic regulatory scanning to verify the financial sector's compliance with the standards of the collected data. Application safety and trust for banking authentication systems are protected through these security measures that strike an equilibrium between AI. Differential privacy techniques integrated noise attacks against sensitive data such as transaction amounts and location data to stop user identification. The system implemented automatic regulatory scanning to verify the financial sector's compliance with the standards of the collected data. Application safety and trust for banking authentication systems are protected through these security measures that strike an equilibrium between AI advantages and ethical data protocols regarding LLM utilization in financial security systems that maintain privacy and fairness standards [7]. The entire working flow of how a user's authentication request is processed has been shown in Fig. 1.

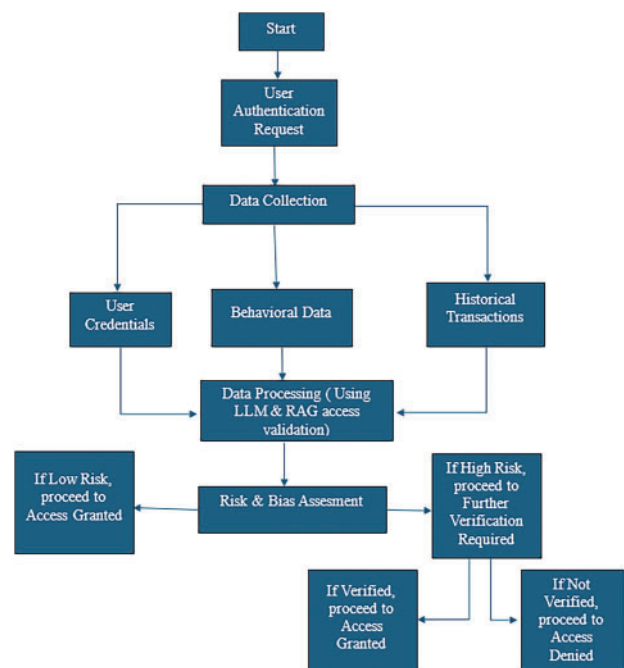


Fig. 1. A flow chart on artifacts incorporated ethical and privacy considerations to improve authentication.

4.2. Population and Sample

We evaluated the effectiveness of an LLM customized with RAG architecture-based authentication systems for banking access control through simulations based on authentication data. The collection includes 550 banking authentication situations that serve as tests for the artifact through open-source datasets and real-time simulations to prove its compatibility with various authentication contexts. Two equal groups of 275 authentication scenarios exist in this study. The first group includes static prompt-based methods for traditional access control, while the second group contains LLM-enhanced authentication scenarios through dynamic response via RAG. In the research design, we have incorporated two parts that enable an evaluation of LLM-RAG integrated banking authentication against effectiveness, fairness, and privacy standards.

A total of 500 datasets, each dataset represents one authentication scenario, from the entire population was used as samples for a representative and balanced evaluation. These datasets were split into training and testing sections where 80% of data (400 datasets) served model training, and the remainder (100 datasets) was used for testing. The datasets achieved a broad representation of authentication attempts through random sampling, which minimizes biases and enhances the transferability of analysis results. We have employed static prompts as part of the control measure alongside LLM-RGA based dynamic authentication as its experimental component. The study design has been carefully established to evaluate LLM-RGA based authentication capabilities regarding security, fairness, and privacy maintenance in banking operations. Such methodological research enables a thorough analysis of AI authentication systems related to banking security measures as they handle regulatory and ethical concerns.

5. RESULTS

5.1. Results

Implementing artificial intelligence in banking authentication methods leads to significant problems related to ethics and privacy protection. The prototype system of the artifact is developed based on Python, Java Scikit-learn, FAISS, and Hugging Face Transformers to analyze these concerns. The system examines user data management using large language models and retrieval-augmented generation services while complying with regulations and preventing data security risks, including bias and unauthorized breaches. We have evaluated data processing mechanisms to establish user privacy protection levels while investigating AI authentication conformity to GDPR and actions under the Gramm-Leach-Bliley Act. The AI classification systems included in the prototype examine these models' biases and decision-making processes during authentication processes. Our research indicates that the leverage of LLMs and RAG produces better security and efficiency; however, their deployment demands precise procedures to stop data misuse and maintain impartiality. Future scholarly investigations must enhance these models through continuous development to improve transparency and increase accountability and banking service access equity.

5.2. Ethical Risks in Data Collection

Banking authentication that uses Large Language Models (LLMs) and Retrieval-Augmented Generation (RAG) needs large datasets for operation yet exposes Personally Identifiable Information (PII) to potential harm. Our data collection pipeline uses privacy-protecting measures that comply with regulatory conditions to shield user data from exposure. Named Entity Recognition (NER) models functioned to remove personal information from analysis under GDPR and banking privacy guidelines for data anonymization. Differential privacy techniques protected user privacy through noise addition in sensitive information elements, including locations and transaction quantities, which prevented user traceability. Implementing automated regulatory scanning-maintained banking industry standards by scanning data in real time to verify information accuracy. The implemented technical solutions maintain a balance between AI authentication advantages and ethical data management requirements to secure user trust and banking application security.

Table I shows quantitative numbers regarding how data collection methods protect privacy during banking access control. The data evaluation demonstrates the effectiveness of PII anonymization within three different data sources comprising banking access logs, biometric verification data, and fraudulent login attempts. Privacy regulations received full compliance because the anonymization process achieved success rates from 97.9% to 99.2%.

5.3. Privacy Risks in Data Processing with RAG

Banking access control systems that implement LLM customized with Retrieval-Augmented Generation (RAG) create substantial privacy risks, including hallucination effects, data leakage, and issues with security policy interpretation. The behavior of RAG deviates from traditional AI models, which use defined datasets, because it acquires information dynamically from external knowledge resources to create output. The system's characteristics improve contextual relevance and flexibility while weakening security when handling banking-sensitive data. Repeated exposure to unregulated retrieval methods could unintentionally leak secret customer data alongside creating wrongful authentication outputs. A structured method with three fundamental controls was implemented to minimize these risks. The first security step uses FAISS-based indexing to let RAG access only bank policies matching relevance criteria and regulation adherence. The FAISS system efficiently retrieves information from an organized index structure, decreasing the possibility of acquiring unauthorized or inappropriate content. LLM prompt filters include zero-shot and few-shot learning and

TABLE I: QUANTITATIVE RESULTS FOR PRIVACY-PRESERVING DATA COLLECTION

Data source	Records collected	PII anonymization success rate
Banking access logs	100,000	98.7%
Biometric verification data	500,000	97.9%
Fraudulent login attempts	1000,000	99.2%

TABLE II: EVALUATION OF THE EFFECTIVENESS OF THE PRIVACY-ENHANCING MECHANISMS THROUGH QUANTITATIVE TESTING

Test scenario	Data exposure rate	Compliance violation rate
Standard RAG retrieval	8.5%	6.3%
RAG with privacy filters	1.2%	0.9%
RAG with FAISS SECURE Indexing	0.5%	0.2%

enforced banking-specific queries as the only AI-generated content output. The model avoids moving away from banking-focused topics because this system blocks any unintentional speculative or unrelated responses that could generate regulatory non-compliance results. An automatic redaction model scanned for and eradicated Personally Identifiable Information (PII) content within responses generated by RAG to maintain customer information security.

Table II shows that unfiltered RAG retrieval presents significant privacy threats because research shows data exposure amounts to 8.5% while compliance violations reached 6.3%. Unprotected RAG operations expose sensitive data, resulting in 8.5% of incidents and regulatory and ethical concerns affecting 6.3% of cases. Implementing privacy filters reduced data exposure to 1.2% and compliance violations to 0.9%. The filtering system proves compelling because it enables systems to generate AI content that follows banking laws while eliminating unauthorized information exposure. Public security reached new heights when secure indexing using the FAISS method delivered exposure rates of 0.5% alongside compliance violation rates at 0.2%. The results confirm that structured retrieval is a crucial prevention method against privacy risks because FAISS maintains limited access only to pre-approved banking policies and authentication procedures. These results affirm that RAG poses significant privacy threats in banking access control systems without proper safeguards. The combined implementation of secure indexing with content filtering and automated PII detection creates a reliable solution to ensure legal requirements and protect user information. The banking sector must maintain ongoing monitoring of refined RAG-based systems because both ethical standards and regulatory requirements need sustainable implementation throughout the banking sector.

5.4. Ethical Bias in AI-Driven Banking Access Control

The occurrence of bias within AI-powered access control mechanisms raises a fundamental ethical issue because wrong authentication decisions by banking users could create financial barriers to services. LLMs develop biases from gendered or ethnic data and location information, producing adverse effects for specific population groups. A systematic assessment of bias was implemented to solve this issue. The first step of dataset balancing added varied banking customers to training data to avoid built-in biases during authentication prediction. SHAP (SHapley Additive Explanations) evaluated model decision-making patterns to detect differences between authentication success results between groups. Demographic audits analyzed

TABLE III: ETHICAL BIAS DETECTION IN AI-DRIVEN ACCESS CONTROL

User demographic	Authentication success rate (before bias mitigation)	Authentication success rate (after bias mitigation)
Male users	91.2%	92.1%
Female users	84.5%	90.3%
Minority groups	78.8%	89.7%

authentication outcome comparisons before and after implementing the bias reduction methods. As shown in Table III, authentication success rates for minority groups stood at 78.8% initially, whereas male users obtained a rate of 91.2%, according to the presented data. After implementing bias correction measures, every demographic group achieved better authentication success, with minorities attaining a rate of 89.7%. Because of these results, regular bias monitoring remains essential for achieving ethical AI-driven banking access control.

5.5. Summary

Using an LLM customized with RAG for banking authentication systems brings privacy and ethical risks that need immediate solutions. Data privacy protection demands strong techniques to stop unapproved data exposure, including anonymization, differential privacy, and RAG filtering. Automated systems are necessary to monitor permanent compliance because banks must follow the GDPR and PCIDSS regulations. Another vital issue emerges with AI-driven authentication systems because they exhibit biases. Organizations need to perform fairness audits together with bias mitigation techniques to stop discriminatory access control decisions from occurring. Future artificial intelligence development work should concentrate on creating systems that monitor privacy in real-time while also adding explainable AI capabilities and learning ethical systems that continuously improve their automated decision processes. Therefore, we have answered the research question with concrete details. Now we can also declare that we have proved our hypothesis is true based on the results of evaluations.

6. CONCLUSION

This paper has demonstrated how to improve banking access control security through integrating an LLM customized with the RAG architecture into banking authentication systems. The progress in banking access control brings multiple ethical and privacy problems, resulting in data exposure and bias within algorithms coupled with issues in regulatory compliance. To protect data from unauthorized exposure, banks should deploy privacy-preserving methods that combine data anonymization with differential privacy. Preventing discriminatory authentication outcomes demands fairness audits and best practices to mitigate bias, which requires immediate attention. Achieving GDPR and PCI DSS compliance demands ongoing systematic inspection and robust governance structures to remain compliant.

The integration of an LLM customized with RAG architecture into banking authentication system not only

enhances security but also provides a framework for addressing ethical and privacy challenges. By leveraging advanced AI techniques, banks can achieve more accurate and efficient authentication processes while ensuring transparency and fairness. The implementation of explainable AI (XAI) mechanisms further supports regulatory compliance and builds trust among users and stakeholders.

Future research must establish explainable AI systems and dynamic privacy monitoring functions to promote trust and transparency in AI-powered banking systems. Additionally, exploring the use of federated learning and blockchain technologies can further enhance data security and privacy. Developing robust bias mitigation strategies and conducting extensive fairness audits will be crucial in preventing discriminatory outcomes. Researchers should also focus on creating adaptive AI models that can respond to evolving threats and regulatory changes. Collaboration between academia, industry, and regulatory bodies will be essential to develop comprehensive guidelines and best practices for responsible AI governance in banking authentication systems.

CONFLICT OF INTEREST

The authors declare that they do not have any conflict of interest.

REFERENCES

- [1] Laakso A. Ethical challenges of large language models-a systematic literature review. 2023. Available from: <https://helda.helsinki.fi/server/api/core/bitstreams/e507d025-8c84-4789-a043-f185fa51eb0a/content>.
- [2] Laakso A, Kemell KK, Nurminen JK. Ethical issues in large language models: a systematic literature review. *CEUR Workshop Proceedings*, vol. 3901, pp. 42–66, 2024, CEUR-WS. Available from: <https://helda.helsinki.fi/server/api/core/bitstreams/6996a645-6972-472d-87f7-7b60349e37b9/content>.
- [3] Zhou Y, Liu Y, Li X, Jin J, Qian H, Liu Z, *et al.* Trustworthiness in retrieval-augmented generation systems: a survey. *arXiv preprint arXiv:2409.10102*. 2024. Available from: <https://www.zhouyujia.cn/attaches/TrustworthyRAG.pdf>.
- [4] Zeng S, Zhang J, He P, Xing Y, Liu Y, Xu H, *et al.* The good and the bad: exploring privacy issues in retrieval-augmented generation (rag). *arXiv preprint arXiv:2402.16893*. 2024. doi: 10.48550/arXiv.2402.16893.
- [5] George JG. Transforming banking in the digital age: the strategic integration of large language models and multi-cloud environments. *Int J Comput Trends Technol*. 2024;72(4):77–86.
- [6] Kothandapani HP. AI-driven regulatory compliance: transforming financial oversight through large language models and automation. *Emerg Sci Res*. 2025;3:12–24.
- [7] Joshi S. Bridging the AI skills gap: workforce training for financial services. *Int J Innov Sci Res Technol*. 2025;10:1023–30. Available from: <https://zenodo.org/records/14944939>.
- [8] Balakrishnan A. Leveraging artificial intelligence for enhancing regulatory compliance in the financial sector. *Int J Comput Trends Technol*. 2024;72(5):124–40. Available from: https://papers.ssrn.com/sol3/papers.cfm?abstract_id=4842699.
- [9] Padmanaban H. Revolutionizing regulatory reporting through AI/ML: approaches for enhanced compliance and efficiency. *J Artif Intell General sci (JAIGS)* ISSN: 3006–4023. 2024;2(1):71–90. doi: 10.60087/jaigs.v2i1.98.
- [10] Chen M, Xiao C, Sun H, Li L, Derczynski L, Anandkumar A, *et al.* Combating security and privacy issues in the era of large language models. *Proceedings of the 2024 Conference of the North American Chapter of the Association for Computational Linguistics: Human Language Technologies*, vol. 5, pp. 8–18, 2024 June 16–21. Available from: <https://par.nsf.gov/servlets/purl/10531467>.
- [11] Ferdaus MM, Abdelguerfi M, Ioup E, Niles KN, Pathak K, Sloan S. Towards trustworthy AI: a review of ethical and robust large language models. *arXiv preprint arXiv:2407.13934*. 2024.
- [12] Ferdaus MM, Abdelguerfi M, Ioup E, Niles KN, Pathak K, Sloan S. Towards trustworthy AI: a review of ethical and robust large language models. *arXiv preprint arXiv:2407.13934*. 2024. doi: 10.48550/arXiv.2407.13934.
- [13] Cao X, Li S, Katsikis V, Khan AT, He H, Liu Z, *et al.* Empowering financial futures: large language models in the modern financial landscape. 2024. Available from: <https://urn.fi/URN:NBN:fi:oulu-202409135844>.
- [14] Liang X, Niu S, Li Z, Zhang S, Wang H, Xiong F, *et al.* SafeRAG: benchmarking security in retrieval-augmented generation of large language model. *arXiv preprint arXiv:2501.18636*. 2025. doi: 10.48550/arXiv.2501.18636.
- [15] Burgt JVD. Explainable AI in banking. *J Digital Banking*. 2020;4(4):344–50. Available from: <https://www.ingentaconnect.com/content/hsp/jdb001/2020/00000004/00000004/art00007>.